CASE STUDY

Cyber Operations as Statecraft: The Cases in The Hacker and the State

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

Many defenders first meet the state hacking of the 2010s through one book. *The Hacker and the State* by Ben Buchanan (2020) sits on the library's Cybersecurity Book List [54] and argues that states hack less to send messages than to change the balance of power, day after day, in peacetime [48] [49] (**Reported**). This study takes the operations that argument rests on and goes back to the record behind them: congressional reports, criminal complaints and indictments, government advisories and attributions, and the vendor reports that first described the malware.

The record is far richer than any single retelling. A House committee report traces the theft of 21.5 million background-investigation records and 5.6 million fingerprints from the US Office of Personnel Management (OPM) back to a first intrusion in July 2012 [2] [3] (**Confirmed**). Mandiant watched one group, which it named APT1 and assessed to be a Chinese military unit, compromise 141 organizations across 20 industries [5] (**Confirmed** as Mandiant's observation and assessment). An FBI affidavit alleges that the same North Korean operators most likely phished their way into Sony Pictures Entertainment in September 2014 and wiped its computers that November, stole about $81 million from Bangladesh Bank in 2016 and released WannaCry in 2017 [12] [14] (**Confirmed** as the complaint's allegations). Two US indictments allege that Russian military intelligence (GRU) officers stole and published Democratic Party email in 2016 and targeted the French presidential campaign in 2017 [28] [32] (**Confirmed**).

What the record also shows is where the popular story runs ahead of it. The book itself was not opened for this study, so its framing is known here only from the author's own interview and from reviews, and every framing claim is graded Reported and attributed to the book by title and author. The British operation against Belgacom rests on journalism built on leaked documents, not on any government statement [9] [10] (**Reported**). Shamoon has no attributed group in ATT&CK [21] (**Confirmed**). And the claim that hacking cannot signal is qualified by the record: the loudest signals in these cases came from the defenders, through

indictments, sanctions and coalition attributions, not from the hacks [7] [16] [44] (**Inferred**).

> Evidence grade: the intrusions, their dates and the government responses are **Confirmed** from primaries. The book's thesis and case selection are **Reported** through an interview and reviews. The Belgacom operation is **Reported**. Technique mappings are graded row by row in Part 9.

Key facts at a glance

Field	Value
The book	*The Hacker and the State* by Ben Buchanan, 2020, listed in the library's book list [54]; the book text was not opened for this study
The book's frame	Shaping versus signaling, and three categories of state hacking: espionage, attack and destabilization [48] [49] (**Reported**)
Cases in this study	OPM (2012 to 2015), APT1 (2006 to 2013), Belgacom and Regin (2010 to 2013), Sony Pictures (2014), Shamoon (2012 and 2016), the 2016 US election, the 2017 French campaign, Bangladesh Bank (2016), Shadow Brokers and WannaCry (2017); Stuxnet, the Ukrainian grid and NotPetya in summary
Largest data theft	OPM: personnel files of 4.2 million people, background investigations on 21.5 million, fingerprints of 5.6 million [2]
Longest observed dwell	APT1: an average of 356 days, the longest 1,764 days [5]
Most systems destroyed	Shamoon 2012: 30,000 or more systems at a Saudi energy company, per Unit 42 [19] (Reported); Sony 2014: thousands of computers inoperable [12]
Largest theft of money	Bangladesh Bank, February 2016: about $81 million lost of an attempt near $1 billion [14]
Widest spread	WannaCry, 12 May 2017: at least 80 of 236 NHS trusts and reports of more than 150 countries [14]
First state actors charged for hacking	Five officers of PLA Unit 61398, indicted 1 May 2014, announced 19 May 2014 [7]
Public attributions	North Korea for Sony (19 Dec 2014) [12] [15]; Russian military for NotPetya (15 Feb 2018) [29]; North Korea for WannaCry with five partner governments (19 Dec 2017) [44]
ATT&CK objects	Groups G0006, G0007, G0016, G0032, G0034, G0082; software including S0019, S0140, S0364, S0366, S0368; campaigns only for the Ukraine grid (C0025, C0028) [52] [53]
Mapped techniques	72 ATT&CK v20.0 Enterprise techniques in the study layer (Part 9)

Key findings

- **Espionage on a national scale ran for years before anyone saw it.** OPM's first known adversarial access dates to July 2012, a date established only from malware found in 2015, and the fingerprint data left on or around 26 March 2015 [3] (**Confirmed**). APT1 held access for an average of almost a year [5] (**Confirmed**).

- **Basic controls were missing at the victims that mattered most.** OPM had not implemented the federal multi-factor authentication requirement, and only one percent of its accounts required PIV cards at the end of fiscal 2014 [2] (**Confirmed**).
- **Stolen credentials did more than exploits.** OPM (a contractor credential, then domain administrator) [2], Sony (phishing for initial access [14], then, per TA14-353A, which does not name Sony, an SMB worm guessing passwords [13]), Shamoon 2 (admin credentials stolen in advance and hard-coded) [19] and the DNC (DCCC credentials) [32] all turned on credentials (**Confirmed**). Only WannaCry, in this set, spread mainly through a software flaw [14] (**Confirmed**).
- **Destruction followed a common recipe.** Sony and Shamoon both used raw-disk drivers to overwrite the master boot record, stopped or rebooted systems, and spread over Windows admin shares [13] [18] [19] (**Confirmed**) (the Sony identification of TA14-353A is **Inferred**).
- **Attribution moved from vendors to governments to courts.** Vendor reports came first (Mandiant's attribution in 2013; Kaspersky's unattributed technical analyses in 2012 and 2014; BAE in 2016) [5] [11] [18] [35]; government attribution followed in under four weeks for Sony [12] and in months for WannaCry [44]; criminal charges followed in years [14] [28] [32] (**Confirmed**).
- **The defenders did the signaling.** The 2014 PLA indictment, the January 2015 sanctions and the December 2017 coalition attribution were deliberate public messages from the victim states [7] [16] [44] (**Inferred**, this study's reading).
- **Stolen state tools became everyone's problem.** Microsoft said the WannaCry exploits came from tools stolen from the NSA, and compared the loss to stolen Tomahawk missiles [43] (**Confirmed** as Microsoft's statement; the provenance is not a government admission).
- **The library needs three corrections and one line flagged for a primary check (Aurora).** The corrections are the Regin page's proxy mapping, Shamoon's group links in `MALWARE_FAMILIES.md` and the absence of a book entry cross-reference; the flagged line is the Operation Aurora attribution in `NOTABLE_INCIDENTS.md` (Part 8.3) (**Inferred**).

Top recommendations

1. **Require phishing-resistant multi-factor authentication for every privileged and remote account.** OPM's one percent PIV coverage [2] and the TA14-353A advice on two-factor for privileged and remote access [13] point the same way (D3FEND Multi-factor Authentication).
2. **Keep offline, tested backups and rehearse recovery from a wiper.** Daily backups with offline copies [13], offline tested backups [38] and restoration media [47] are the common advice across 2014, 2017 and 2022.
3. **Patch remotely reachable services fast and retire legacy protocols.** MS17-010 shipped on 14 March 2017 [36]; WannaCry spread from 12 May [14]. Disable SMBv1 and block SMB at the boundary [38] (D3FEND Network Traffic Filtering).
4. **Limit administrative privilege and credential caching, and watch domain accounts.** The Sony-era worm and Shamoon 2 both moved on administrator credentials, brute-forced or stolen in advance [13] [19] (D3FEND Credential Hardening, Domain Account Monitoring).
5. **Segment and isolate critical systems.** VLAN segmentation of critical networks [13] and segmentation in current destructive-malware guidance [47]; for payment systems, the SWIFTLIVE server at Bangladesh

Bank was reached by lateral movement [14].

6. **Treat contractor access as your own attack surface.** The OPM intruder used a contractor's credential [2].
7. **Plan the attribution and disclosure path before the incident.** The cases show the public response (attribution, sanctions, charges) is part of the defense; agree in advance who speaks and with what evidence (**Inferred**).

Scope and method

This study covers the state operations of 2006 to 2018, sorted here into the book's three categories (**Inferred**): espionage (OPM, APT1 and the 2014 indictment, the 2013 program disclosures and, as this study's own choice, Dual_EC, Belgacom and Regin), attack (Sony Pictures, Shamoon, with Stuxnet, the Ukrainian grid and NotPetya in summary) and destabilization (the 2016 US election, the 2017 French campaign), plus the financial and blowback cases (Bangladesh Bank, Shadow Brokers and WannaCry). It follows the method in the case studies README: primary sources first, every claim graded, numbers given as the source states them, and figures checked against the source they cite. Every source in the Sources table was opened on 3 November 2026. Direct quotations are kept under 15 words. Facts taken from complaints and indictments are allegations that have not been tested at trial.

The book was not opened. Its framing comes from the author's interview in *The Diplomat* [48] and from reviews [49] [50] [51]. Two reviews name three of the book's cases: Sony and the 2016 election [49], and the Shadow Brokers leak [50]. For the other operations here, this study examines the state operations of the book's period and categories, and does not claim that the book tells each one or tells it the same way (**Inferred**).

Home studies. Where another study in this series is the home for an event, this study gives one paragraph and links: Stuxnet lives in Stuxnet; the Ukrainian grid attacks of 2015 and 2016 and NotPetya live in Sandworm: The Operations in the Public Record; the Shadow Brokers leak and the WannaCry outbreak live in The Zero-Day Trade and Its Fallout, so Part 5.2 keeps only the attribution sequence the book's blowback case rests on. Sony 2014, Shamoon, the 2016 election, the French campaign and Bangladesh Bank live here. The actor records behind these cases live in the actor studies: China (APT1 and OPM), Russia (APT28, APT29 and Sandworm Team), North Korea (Lazarus Group and APT38), Iran (the Shamoon wiper lineage) and the United States (the Equation platform). For the long Chinese espionage line after APT1, see APT41: the public record.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: a congressional or oversight report, a court filing, a government advisory or statement, a vendor's own analysis, the MITRE page or the library's own data files
Reported	Stated only in journalism, an interview or a review; this includes every claim about the book's own argument
Demonstrated	A public reproduction exists that others can check (no claim in this study needed this grade)
Inferred	This study's own reasoning from Confirmed facts, labelled as such

Part 1: the book and its frame

1.1 Shaping and signaling

In his interview with *The Diplomat*, Buchanan sets the Cold War emphasis on signaling, showing resolve and threatening and coercing an adversary, against what he calls shaping, which he describes as "stacking the deck or stealing cards" [48] (**Reported**). Tom Uren's review in *Inside Story* gives the book's reason: hacking tools need secrecy and their operations are hard to read, so they make poor signals but excellent shaping tools [49] (**Reported**). The author also describes the contest between government hackers as fierce, nearly continuous and daily, not something kept for wartime [48] (**Reported**).

1.2 Three categories

Uren describes the book's structure as three categories: espionage, attack and destabilization, the third being disruption that makes it possible to interfere with elections [49] (**Reported**). He places North Korea's attack on Sony Pictures over the film *The Interview* among the attack cases [49], and Russia's 2016 interference, through social media, the hacking of Democratic Party institutions and the release of stolen documents, among the destabilization cases [49] (**Reported**). Angus Parker's review in *Geographical*, republished by Georgetown's CSET, cites the book's use of the Shadow Brokers leak of NSA files as an example of shaping and gives the group's active period as 2015 to 2018 [50] (**Reported**).

1.3 The critics

Two reviewers qualify the thesis. Parker says the book does not concentrate enough on the explicit political implications of each attack [50] (**Reported**). A 2025 review by Enescan Lorci in *Uluslararasi Iliskiler* says contemporary scholarship finds cyber capabilities increasingly instrumental for signaling, against the book's view [51] (**Reported**; only the abstract was opened).

1.4 How the record tests the frame

The primary record in Parts 2 to 5 supports the shaping half of the argument well: OPM, APT1 and the SWIFT thefts changed what one side knew or held, quietly and for years (**Inferred**). It complicates the signaling half. In these cases the clear signals were the victim states' responses: an indictment of serving officers in 2014 [7], sanctions two weeks after the FBI's attribution and under six weeks after the attack [12] [16], and a six-government attribution of WannaCry in 2017 [44] (**Inferred**, this study's reading). That fits the book's point that the operations themselves were poor signals, while showing that the contest around them was full of signals.

Part 2: espionage

2.1 OPM, 2012 to 2015

The House Committee on Oversight and Government Reform majority staff published its report on the breach on 7 September 2016 [1] (**Confirmed**). With its timeline of key events [3], it gives the clearest public record of how the intrusion unfolded.

- **First access, July 2012.** The first known adversarial access dates to July 2012, established from malware found in 2015 [3] (**Confirmed**).

- **The first warning, March 2014.** On 20 March 2014 US-CERT told OPM that a third party had reported data exfiltration. OPM then watched the first actor, "Hacker X1", for about two months while manuals and system documentation were taken [2] (**Confirmed**).
- **The credential path.** The attacker used a credential belonging to KeyPoint, a background-investigation contractor, for initial access, then obtained domain administrator credentials and kept persistence through malware [2] (**Confirmed**).
- **Reaching the crown jewels, June 2014.** In June 2014 the adversary ran a remote desktop session to sensitive background-investigation servers and likely first reached the mainframe [3] (**Confirmed**).
- **The thefts.** Background-investigation files left between July and August 2014, personnel records in December 2014 through the Interior Department data center that held OPM data, and fingerprint data on or around 26 March 2015 [3] (**Confirmed**).
- **Discovery, April 2015.** On 15 April 2015 OPM told US-CERT about suspicious traffic to `opmsecurity.org`, a domain registered in April 2014 under the alias "Steve Rogers", which last beaconed in March 2015 [3] (**Confirmed**).
- **Disclosure.** OPM gave public notice on 4 June 2015 for 4.2 million personnel records and on 9 July 2015 for more than 20 million background-investigation records [3] (**Confirmed**).

The totals, as the report states them, are personnel files of 4.2 million people, background-investigation information on 21.5 million and fingerprints of 5.6 million; a footnote gives an aggregate of 22.1 million people [2] (**Confirmed**). The report's diagnosis of the defensive failure is blunt: OPM had not implemented OMB's multi-factor authentication requirement, and only one percent of accounts required PIV cards at the end of fiscal 2014 [2] (**Confirmed**).

Pages i to vii of the report, the part read for this study, name no attributed actor, so this study links no ATT&CK group to OPM (attribution beyond those pages not checked).

2.2 APT1 and Unit 61398, 2006 to 2014

Mandiant's February 2013 report observed APT1 compromise 141 organizations across 20 industries since 2006 and assessed it to be Unit 61398 of the People's Liberation Army, the 2nd Bureau of the General Staff Department's 3rd Department [5] (**Confirmed**; the attribution is Mandiant's assessment). The figures are Mandiant's own: an average access of 356 days, a longest of 1,764 days, up to 6.5 TB of compressed data from one organization in ten months, and 87 percent of victims headquartered in English-speaking countries [5] (**Confirmed**).

The report is also a catalogue of tradecraft:

- Spear phishing with attached or linked ZIP files was the group's most common entry, and WEBC2 backdoors read their commands from web pages [5] (**Confirmed**).
- Public credential tools did the rest: cachedump, fgdump, gsecdump (for the SAM, cached domain credentials and LSA secrets), lslsass, mimikatz, a pass-the-hash toolkit and pwdump7 [5] (**Confirmed**).
- Stolen data was packed into compressed archives that were deleted after the theft; GETMAIL and MAPIGET stole email; HTRAN was seen 767 times relaying traffic through hop points [5] (**Confirmed**).

Fifteen months later the United States charged five of the unit's officers. On 1 May 2014 a grand jury in the Western District of Pennsylvania indicted five officers of 3PLA, Second Bureau, Third Office, MUCD 61398, on

31 counts including economic espionage and theft of trade secrets; the charges were announced on 19 May 2014 [7] (**Confirmed**). The FBI calls these the first criminal charges against known state actors for hacking. The six victims were US companies in nuclear power, metals and solar, targeted while negotiating with or litigating against Chinese state-owned enterprises [7] (**Confirmed**). The FBI page names the unit, not APT1; connecting the indicted officers to Mandiant's APT1 runs through the shared unit number (**Inferred**).

On 25 September 2015, during President Xi Jinping's state visit, the White House fact sheet recorded that neither government would conduct or knowingly support cyber-enabled theft of intellectual property or trade secrets for commercial advantage. It set up a high-level joint dialogue on cybercrime, with a first meeting by the end of 2015, then twice a year, and a hotline, plus a senior experts group on international norms [6] (**Confirmed**). The fact sheet records commitments; whether the theft declined afterwards is not a question any source here answers (**Inferred**).

2.3 The 2013 program disclosures and Dual_EC

The Privacy and Civil Liberties Oversight Board's report of 2 July 2014 records that in June 2013 the press first reported two classified NSA collection programs from documents disclosed by Edward Snowden: bulk telephone metadata under Section 215 and content collection under Section 702 [4] (**Confirmed**). It describes two kinds of Section 702 acquisition. PRISM sends selectors to US providers, who are compelled to assist. Upstream collection compels the help of backbone providers, includes "about" collection and multiple-communication transactions, and is received only by NSA [4] (**Confirmed**).

The same year touched cryptographic standards. After news reports in September 2013, NIST recommended against the Dual_EC_DRBG random number generator, and on 21 April 2014 removed it from SP 800-90A Rev. 1, citing its own evaluation and a lack of public confidence [8] (**Confirmed**). NIST's statement does not name the NSA; the NSA link rests on press reporting not opened for this study (not checked).

2.4 Belgacom and Regin, 2010 to 2014

Everything specific to Belgacom here comes from journalism built on leaked documents, so it is graded Reported. *The Intercept* reported that "Operation Socialist" was GCHQ's codename for the hack of Belgium's largest telecoms company. The staged intrusion ran from 2010 to 2011 and surged by December 2011. Email problems followed in summer 2012, and Belgacom and Fox-IT found the malware in June 2013. A partial remote deletion took place on 30 August 2013, and *Der Spiegel* published on 20 September 2013 [9] (**Reported**).

- **Getting in.** GCHQ identified Belgacom engineers and administrators through NOCTURNAL SURGE and cookie matching. It then used Quantum Insert to redirect three engineers to a malicious fake LinkedIn page, and HACIENDA scanned the networks [9] (**Reported**).
- **The target.** The targets included Belgacom's roaming hub, GPRS links and VPN tunnels to partner operators, and the aim was to intercept traffic before encryption. Belgacom denied that customer data was compromised [9] (**Reported**).
- **The malware.** *The Intercept* identified the malware as Regin; the codenames Legspin and Hopscotch appear both in GCHQ documents and in Regin samples [9] (**Reported**).
- **The investigation.** In 2018 *The Intercept* and *de Volkskrant* reported the Belgian findings. The malware was disguised as legitimate Microsoft software and stored data in encrypted, compressed containers. Three engineers were hacked through a fake LinkedIn site. The evidence was judged circumstantial,

Europol declined to help, and no charges were expected [10] (**Reported**).

Regin itself is on firmer ground. Kaspersky's analysis of 24 November 2014 describes a multi-stage platform. Its stages are stored in NTFS Extended Attributes or the registry and its payloads in encrypted virtual file systems. It spreads through Windows admin shares, talks to its controllers over ICMP raw sockets, HTTP and HTTPS, and SMB named pipes, and relays through internal "drones" [11] (**Confirmed** for Regin). Kaspersky also reports that the Belgian cryptographer Jean-Jacques Quisquater announced an intrusion in February 2014 and that the samples were Regin. It found a 2008 GSM base station controller log showing commands on 136 cells [11] (**Confirmed**). Tying Regin's technique set to Belgacom in particular rests on *The Intercept*, so Part 9 grades Belgacom-specific techniques Reported and Regin-platform techniques Confirmed only for Regin [9] [11] (**Inferred**).

Part 3: attack

3.1 Sony Pictures Entertainment, 2014

The criminal complaint against Park Jin Hyok (C.D. Cal. case 18-1479, signed 8 June 2018, unsealed September 2018) is the fullest public record. It charges conspiracy (18 USC 371) and conspiracy to commit wire fraud (18 USC 1349) for a period from no later than 2 September 2014 to at least 3 August 2017. It says Park worked for Chosun Expo, a North Korean government front linked to "Lab 110" [14] (**Confirmed**).

- **Reconnaissance, 22 September 2014.** A North Korean IP address scanned a Sony Pictures Entertainment (SPE) web server and browsed SPE sites until 30 October 2014 (para 75) [14] (**Confirmed**).
- **Personas.** Fake Facebook personas posted links on actors' pages in September 2014; the "Frank David" email account was created through a proxy service on 21 November 2014 (para 63) [14] (**Confirmed**).
- **Initial access, 25 September 2014.** A spear-phishing email from `bluehotrain@hotmail.com`, under the name "Nathan Gonsalez", reached an SPE user with a `1drv.ms` link. A file named "...Advertising Video Clips (Adobe Flash).exe" was found, and SPE systems beaconed to a Chinese IP seven times between 26 September and 6 October 2014. The affiant assesses this appears to be how the subjects gained access (para 121) [14] (**Confirmed** for the record; the access path is the affiant's assessment).
- **Impact, 24 November 2014.** A "Hacked By #GOP" pop-up appeared on SPE workstations, and about 21 Twitter accounts were also hit (paras 64, 66). The Destover malware had a dropper, a wiper, and a web server for the pop-up and a gunshot sound file (para 72). One piece hard-coded about 10,000 SPE hostnames, and nine Unix and Linux scripts were found, five apparently written for SPE (para 73). The wiper overwrote the master file table and the master boot record [14] (**Confirmed**).

US-CERT's alert TA14-353A of 19 December 2014 describes the toolkit without naming Sony, calling the victim "a major entertainment company" [13] (**Confirmed** for the alert's content; reading it as Sony's toolkit is **Inferred** from its date and from the complaint's description of the same wiper [14]):

Component	Behaviour in TA14-353A [13]
SMB worm	Brute-forces passwords; uses `admin$` and `shared$`; copies `taskhostXX.exe`; sets its timestamp to match `calc.exe`; starts through WMIC
Listening implant	TCP 195 and 444; messages XOR-encoded with 0x1F

Component	Behaviour in TA14-353A [13]
Backdoor	Uses UPnP to open router ports
Proxy tool	TCP 443
Destructive hard-drive tool	Overwrites up to four physical drives and the MBR
Dropper	Installs the service `WinsSchMgmt`; C2 on TCP 8080 and 8000 to hard-coded IPs; stops the Exchange information store service; sleeps 120 minutes, then reboots; carries two commercial raw-disk drivers

The response came fast and from the top.

- **FBI, 19 December 2014.** The FBI concluded the North Korean government was responsible. It cited similarities in code, encryption algorithms, deletion methods and networks with known North Korean malware, and North Korean IPs communicating with IPs hard-coded in the wiper. It also cited tool similarities to the March 2013 attack on South Korean banks and media. Thousands of SPE computers were inoperable and SPE took its network offline [12] (**Confirmed**).
- **The President, 19 December 2014.** President Obama confirmed North Korea's responsibility and said the US would respond proportionally, at a place, time and manner of its choosing. He said there was no indication another country acted with North Korea [15] (**Confirmed**).
- **Treasury, 2 January 2015.** Treasury announced a new Executive Order and designated the Reconnaissance General Bureau (RGB), KOMID, KOTC and ten officials, citing the Sony attack [16] (**Confirmed**).
- **Later charges.** The FBI's wanted notice for Park adds a further warrant on 8 December 2020 and says the conspiracy is what researchers call Lazarus Group and APT38 [17] (**Confirmed**).

ATT&CK's G0032 Lazarus Group page says the group is reportedly responsible for the November 2014 Sony wiper attack, which Novetta identified as part of Operation Blockbuster, and lists Guardians of Peace among its aliases [22] (**Confirmed** for what the page says). Its destructive procedures name WhiskeyAlfa, WhiskeyBravo, WhiskeyDelta and SHARPKNOT, and say MBR wipers have been used since at least 2009, but none of those procedure texts names Sony; the Sony link comes from the group description and the Novetta citations [22] (**Confirmed**). Of the Sony-era wiper components, only RawDisk has an ATT&CK software id, S0364, which the library's data links to Lazarus Group [52] (**Confirmed**).

3.2 Shamoon, 2012 and 2016

Kaspersky's 16 August 2012 analysis found samples whose PDB path contains "Shamoon" and "ArabianGulf", a 900 KB executable with XOR-encrypted resources, and a driver signed by EldoS that gives raw disk access to wipe the MBR. Kaspersky judged it was not the "Wiper" that hit Iran in April 2012 and called it the work of copycats [18] (**Confirmed**).

Unit 42's later recap says the August 2012 attack on a Saudi energy company damaged 30,000 or more systems, displayed an image of a burning American flag, and fell on Lailat al Qadr [19] (**Reported**, Unit 42's recap; no primary for the 30,000 figure was opened). Kaspersky's March 2017 report names the 2012 targets as Saudi Aramco and RasGas, notes that a group calling itself the "Cutting Sword of Justice" claimed the 2012 attack on Pastebin, and dates Shamoon 2.0 waves to 17 November 2016, 29 November 2016 and 23 January

2017 [20] (**Confirmed**).

Shamoon 2, as Unit 42 analysed it on 30 November 2016 [19] (**Confirmed**):

- Wiping was set for 20:45 on 17 November 2016, the end of the Saudi work week.
- The malware carried hard-coded internal domain names and administrator credentials stolen beforehand.
- It disabled UAC remote restrictions through `LocalAccountTokenFilterPolicy`, connected with `NetUseAdd` using the stolen credentials, and wrote `system32\ntssrvr32.exe`.
- It ran as the service `ntssrv`, displayed as "Microsoft Network Realtime Inspection Service", or as a job created with `NetScheduleJobAdd`.
- Its HTTP C2 used a `shinu` parameter carrying the tick count, IP address, OS version and keyboard layout, and could download and run more programs.
- The wiper installed RawDisk as `drdisk.sys`, the same driver as in 2012. It had F, R and E modes: F overwrote files with an image of Alan Kurdi and E encrypted with RC4. It queried the `FirmwareBootDevice` and `SystemBootDevice` registry keys and set the system clock to August 2012 to use RawDisk's temporary licence. It then forced an immediate reboot.

Attribution is the weak point. Kaspersky's 2017 report contrasts StoneDrill's Persian resource sections with Shamoon's Arabic-Yemen ones. It concludes the two are likely the work of different groups with aligned interests and does not rule out false flags [20] (**Confirmed** as Kaspersky's assessment). ATT&CK's S0140 Shamoon page (alias Disttrack, version 2.2, modified 17 November 2024) says the Iranian group known as the Cutting Sword of Justice first used it in 2012. It notes Shamoon 2 in 2016 and Shamoon 3 in 2018, lists no associated group, and does not name Saudi Aramco [21] (**Confirmed**). This study therefore links Shamoon to no ATT&CK group.

3.3 Stuxnet (summary; home study linked)

ATT&CK's S0603 Stuxnet entry says it was discovered in 2010, with components used as early as November 2008, and that it used multiple zero-days and a Windows rootkit [25] (**Confirmed**). The technical record, the timeline, attribution and the ATT&CK for ICS mapping live in Stuxnet.

3.4 The Ukrainian grid and NotPetya (summary; home study linked)

On 23 December 2015 remote intrusions at three Ukrainian regional power distribution companies cut power to about 225,000 customers. The intruders operated breakers remotely through remote administration tools or ICS client software over VPN, with credentials obtained beforehand. They ran KillDisk at the end, corrupted serial-to-Ethernet firmware and scheduled UPS disconnects. BlackEnergy was present, its role unknown [27] (**Confirmed**). The 2020 indictment of six officers of GRU Unit 74455 (Sandworm Team) charges spearphishing from late spring 2015 and the use of BlackEnergy and KillDisk. It also charges the 6 December 2016 attack on the Ministry of Finance and State Treasury and the 17 December 2016 Industroyer attack on a transmission company, which cut power in Kyiv for about an hour. NotPetya came through the M.E.Doc update server and hit victims including Heritage Valley, TNT Express and a pharmaceutical maker with nearly $1 billion in losses; the indictment also charges Olympic Destroyer in 2018 [28] (**Confirmed**). The White House attributed NotPetya to the Russian military on 15 February 2018 [29], and CISA's CrashOverride alert, updated in 2021, attributes the 2016 malware to Russian nation-state actors [30] (**Confirmed**). CISA's TA17-181A describes NotPetya's spread through stolen credentials (a modified Mimikatz), PsExec, WMIC, EternalBlue and EternalRomance, and warns recovery may be impossible even if the ransom is paid [45] (**Confirmed**). ATT&CK models the grid attacks as campaigns C0028 (2015) and C0025 (2016) [26] [52]. The full record lives in Sandworm: The Operations in the Public Record.

Part 4: destabilization

4.1 The 2016 US election: the GRU operation

On 13 July 2018 a grand jury indicted twelve officers of GRU Units 26165 and 74455 for hacking the Democratic Congressional Campaign Committee (DCCC), the Democratic National Committee (DNC) and the Clinton campaign, and for releasing the stolen material as "DCLeaks" and "Guccifer 2.0" [31] (**Confirmed**). The indictment [32] gives the operation in dated steps (**Confirmed** throughout):

- **Phishing, March 2016.** On about 19 March 2016 a spoofed Google security notice with a shortened link was sent to the Clinton campaign chairman; more than 50,000 emails were stolen by 21 March. More than 300 people were targeted from March 2016.
- **Reconnaissance, 15 March and 7 April 2016.** The officers ran technical queries for DNC and DCCC IP configurations and searched open sources about the networks.
- **Implants, April to June 2016.** X-Agent was installed on at least ten DCCC computers, with keylogging and screenshot functions run from a control panel the indictment calls "AMS". The DNC was entered on 18 April 2016 with stolen DCCC credentials. An overseas computer was configured to relay X-Agent traffic to the AMS panel.
- **Theft.** Documents were gathered and compressed with a public tool, and X-Tunnel moved them through encrypted channels to a GRU-leased computer in Illinois. Between about 25 May and 1 June 2016 the DNC's Microsoft Exchange server was hacked and thousands of work emails stolen.
- **Cover-up.** Event logs were cleared on a DNC computer on 13 May 2016, CCleaner was used on the DCCC network on 1 June, and AMS panel logs were deleted on 20 June.
- **Persistence despite remediation.** A Linux X-Agent talking to `linukal.net` stayed on the DNC network until about October 2016, although a security company's remediation began in June 2016.

- **Redirect.** The lookalike domain `actblues.com` was registered on 14 June 2016 and the DCCC website was changed to send visitors to it.
- **Release.** DCLeaks.com was registered and promoted through fictitious Facebook and Twitter accounts. The Guccifer 2.0 persona appeared on 15 June 2016 claiming to be a lone Romanian hacker [31]. Posing as Guccifer 2.0, the conspirators sent an encrypted archive of DNC documents to "Organization 1" on 14 July 2016, which released more than 20,000 emails on 22 July [32].
- **Election infrastructure.** In about July 2016 Kovalev and others hacked a state board of elections website and stole data on about 500,000 voters, and in August hacked a voter-registration software vendor [32].

The DOJ release says the indictment does not allege that the conduct changed the vote count or the outcome [31] (**Confirmed**). The FBI's wanted listing names the defendants and notes that Osadchuk and Kovalev are charged separately with targeting election administration: state boards, secretaries of state and vendors [33] (**Confirmed**).

4.2 The 2016 US election: the earlier intrusion and the influence operation

The US government's joint analysis report JAR-16-20296A of 29 December 2016 says two Russian intelligence actors were in a US political party's network. APT29 entered in summer 2015 through a spearphishing link campaign sent to more than 1,000 recipients; it escalated privileges, enumerated Active Directory and exfiltrated email over encrypted connections. APT28 entered in spring 2016 by sending recipients to a fake webmail password-change page and used the harvested credentials [46] (**Confirmed**). ATT&CK's G0007 APT28 page ties the group to GRU Unit 26165 and records the reported 2016 compromise of the Clinton campaign, the DNC and the DCCC, with CHOPSTICK (S0023) and XTunnel (S0117) among its software [24] (**Confirmed**).

The influence operation is a separate record. The FBI says Yevgeniy Prigozhin was the main funder of the Internet Research Agency in St. Petersburg. From early 2014 its operations used hundreds of fictitious personas and stolen US identities and bought US server space, and he was charged on 16 February 2018 with conspiracy to defraud the United States [34] (**Confirmed**). ATT&CK has no group object for the Internet Research Agency [52] (**Confirmed**).

4.3 The 2017 French presidential campaign

The 2020 indictment of six Unit 74455 officers sets out the French operation [28] (**Confirmed** throughout):

- From about 3 April to 3 May 2017 the officers ran seven spearphishing campaigns. They targeted more than 100 members of En Marche!, other French politicians and local government addresses ahead of the 7 May vote.
- On 21 April 2017 Kovalev tested a Google Docs-themed technique and built a malware-laced document about who could talk to journalists. An account mimicking Macron's press secretary sent it to about 30 staff.
- From 12 to 26 April 2017 a GRU-controlled social media account offered purported internal documents of En Marche!, Macron's movement, to French individuals.
- On 3 and 5 May 2017 "unidentified individuals" began leaking purported documents of En Marche!, and the indictment does not attribute the leak itself to the defendants.

The FBI's notice for Yuriy Andrienko records that the grand jury in the Western District of Pennsylvania returned the indictment on 15 October 2020. It covers operations including the French campaign, NotPetya and the 2018 Olympics [42] (**Confirmed**).

Part 5: money and blowback

5.1 Bangladesh Bank and the SWIFT operations, 2014 to 2016

The Park Jin Hyok complaint [14] (**Confirmed** throughout unless marked) covers the North Korean financial operation as well as Sony:

- **Reconnaissance, 7 to 8 October 2014.** Reconnaissance of Bangladeshi banks, including visits to their websites, began as early as these dates.
- **Initial access, from 29 January 2015.** Resume-themed spearphishing emails carried a link to `Resume.zip` and likely gave initial access to Bangladesh Bank.
- **Implants.** The NESTEGG in-memory backdoor was installed as a Windows service and its dropper securely erased from disk. MACKTRUCK and other Lazarus malware used a fake TLS protocol over port 443 for command and control.
- **Reaching SWIFT, 29 January 2016.** The intruders moved laterally to the SWIFTLIVE system running SWIFT Alliance Access, made at least four login attempts and deleted some of the evidence.
- **The theft, February 2016.** The attackers crafted and authenticated SWIFT messages from Bangladesh Bank terminals that told the Federal Reserve Bank of New York to transfer the funds. About $81 million was lost in an attempted theft approaching $1 billion. A $20 million transfer to Sri Lanka was stopped, and the rest was laundered through Philippine accounts and casino junkets.
- **Hiding it.** The heist malware tampered with printed or PDF confirmations and with the Oracle message database, and other malware deleted the evidence.
- **The links.** The FBI linked intrusions at Bangladesh Bank, a bank in Vietnam and other victims to the same subjects and to the Sony attack.

BAE Systems' analysis of 25 April 2016 adds the mechanics. The tool `evtdiag.exe` patched two bytes of `liboradb.dll` in memory, ran SQL `DELETE` statements against the `SAAOWNER` database and altered printed SWIFT confirmations; BAE put the attempted theft at $951 million [35] (**Confirmed** as BAE's analysis). ATT&CK's G0082 APT38 page (version 4.0, modified 9 October 2026) describes a North Korean RGB group for financial operations that targets SWIFT endpoints and credits it with the 2016 heist of USD 81 million [23] (**Confirmed**). It maps the SWIFT fraud tool DYEPACK to stored, transmitted and runtime data manipulation, though DYEPACK has no ATT&CK software id, and lists KillDisk (S0607) among APT38's software [23] (**Confirmed**).

5.2 The Shadow Brokers and WannaCry, 2017

The leak, the exploit and the outbreak are told in full in The Zero-Day Trade and Its Fallout; this section keeps the sequence from patch to attribution that the book's blowback case rests on. From patch to coalition attribution the sequence took nine months, 14 March to 19 December 2017; the attribution revision and the KEV listings came later.

Date	Event	Source	Grade
14 Mar 2017	Microsoft bulletin MS17-010 fixes SMBv1 flaws CVE-2017-0143 to CVE-2017-0148, rated Critical for remote code execution	[36]	Confirmed
15 Apr 2017	A group calling itself the Shadow Brokers publicly releases an exploit for CVE-2017-0144	[14]	Confirmed
15 Apr 2017	Microsoft says most of the released exploits were already patched: EternalBlue, EternalChampion, EternalRomance and EternalSynergy by MS17-010; three did not reproduce on supported platforms	[37]	Confirmed
12 May 2017	WannaCry Version 2 begins spreading; at least 80 of 236 NHS trusts are affected and 6,912 appointments cancelled; Europol reports cite more than 150 countries	[14]	Confirmed
12 May 2017	CISA TA17-132A describes the `mssecsvc2.0` service, spread over TCP 445 and the kill-switch domain	[38]	Confirmed
14 May 2017	Microsoft says the exploits were drawn from those stolen from the NSA and compares the loss to stolen Tomahawk missiles	[43]	Confirmed (Microsoft's statement)
19 Dec 2017	The UK says the NCSC assesses it highly likely that North Korean actors known as Lazarus Group were behind WannaCry	[39]	Confirmed
19 Dec 2017	The US attributes WannaCry to the North Korean government, joined by the UK, Australia, Canada, New Zealand and Japan	[44]	Confirmed
7 Jun 2018	TA17-132A revised to add attribution to the North Korean government	[38]	Confirmed
3 Nov 2021 and 10 Feb 2022	CISA KEV adds CVE-2017-0143 and CVE-2017-0144	[41]	Confirmed

The complaint describes WannaCry spreading as a worm through CVE-2017-0144, using the victim's network configuration to scan its local network and also scanning internet hosts; paying the ransom did not decrypt files [14] (**Confirmed**). At the attribution briefing, Tom Bossert said the US discloses about 90 percent of the vulnerabilities it finds and did not confirm that the exploit came from the NSA [44] (**Confirmed**). The NSA provenance therefore rests on Microsoft's assertion [43], not on any government admission among the sources opened. NVD lists `NVD-CWE-noinfo` for CVE-2017-0144, so no CWE is assigned to it [40] (**Confirmed**). The broader market for exploits is the subject of The Zero-Day Trade and Its Fallout.

Part 6: the timeline

Date	Event	Category	Source	Grade
2006	APT1's observed compromises begin	Espionage	[5]	Confirmed
2008	Earliest Stuxnet components (November); a GSM base station controller log with commands on 136 cells (Regin)	Attack; espionage	[25] [11]	Confirmed
2010 to 2011	Staged intrusion into Belgacom, surging by December 2011	Espionage	[9]	Reported
Jul 2012	First known adversarial access to OPM	Espionage	[3]	Confirmed
Aug 2012	Shamoon wipes 30,000 or more systems at a Saudi energy company	Attack	[18] [19]	Confirmed (wiper, [18]); Reported (30,000 figure, [19])
Feb 2013	Mandiant publishes APT1	Espionage	[5]	Confirmed
Jun 2013	Press reports of NSA programs from Snowden documents; Belgacom and Fox-IT find the malware	Espionage	[4] [9]	Confirmed; Reported
Sep 2013	*Der Spiegel* publishes on Belgacom (20 Sep); NIST recommends against Dual_EC_DRBG	Espionage	[9] [8]	Reported; Confirmed
Early 2014	Internet Research Agency operations begin	Destabilization	[34]	Confirmed
Feb 2014	Quisquater announces an intrusion; the samples are Regin	Espionage	[11]	Confirmed
20 Mar 2014	US-CERT notifies OPM of exfiltration	Espionage	[2]	Confirmed
21 Apr 2014	NIST removes Dual_EC_DRBG from SP 800-90A Rev. 1	Espionage	[8]	Confirmed
1 May 2014	Five Unit 61398 officers indicted (announced 19 May)	Response	[7]	Confirmed
Jun 2014	RDP session to OPM background-investigation servers	Espionage	[3]	Confirmed
2 Jul 2014	PCLOB Section 702 report	Oversight	[4]	Confirmed
Jul to Aug 2014	OPM background-investigation files exfiltrated	Espionage	[3]	Confirmed
22 Sep 2014	North Korean IP scans an SPE web server	Attack	[14]	Confirmed
25 Sep 2014	Spear-phishing email reaches an SPE user	Attack	[14]	Confirmed
7 to 8 Oct 2014	Reconnaissance of Bangladeshi banks begins	Theft	[14]	Confirmed
24 Nov 2014	Sony wiper and "Hacked By #GOP"	Attack	[14]	Confirmed
24 Nov 2014	Kaspersky publishes Regin	Espionage	[11]	Confirmed
Dec 2014	OPM personnel records exfiltrated	Espionage	[3]	Confirmed
13 Dec 2014	*The Intercept* publishes Operation Socialist	Espionage	[9]	Reported

Date	Event	Category	Source	Grade
19 Dec 2014	FBI attributes Sony to North Korea; TA14-353A; the President promises a proportional response	Response	[12] [13] [15]	Confirmed
2 Jan 2015	Treasury sanctions citing Sony	Response	[16]	Confirmed
29 Jan 2015	Resume-themed phishing of Bangladesh Bank begins	Theft	[14]	Confirmed
26 Mar 2015	OPM fingerprint data exfiltrated, on or around this date	Espionage	[3]	Confirmed
15 Apr 2015	OPM reports `opmsecurity.org` traffic to US-CERT	Espionage	[3]	Confirmed
4 Jun and 9 Jul 2015	OPM public notices	Response	[3]	Confirmed
Summer 2015	APT29 enters a US political party's network	Destabilization	[46]	Confirmed
25 Sep 2015	US and China commit against cyber-enabled commercial IP theft	Response	[6]	Confirmed
23 Dec 2015	Ukrainian grid outages, about 225,000 customers	Attack	[27]	Confirmed
29 Jan 2016	Intruders reach Bangladesh Bank's SWIFTLIVE system	Theft	[14]	Confirmed
Feb 2016	Bangladesh Bank loses about $81 million	Theft	[14]	Confirmed
Mar to Jun 2016	GRU phishing, implants and theft at the Clinton campaign, DCCC and DNC	Destabilization	[32]	Confirmed
25 Apr 2016	BAE publishes "Two bytes to $951m"	Theft	[35]	Confirmed
15 Jun 2016	Guccifer 2.0 appears	Destabilization	[31]	Confirmed
Jul 2016	State board of elections website hacked; DNC emails released 22 Jul	Destabilization	[32]	Confirmed
7 Sep 2016	House Oversight OPM report	Oversight	[1]	Confirmed
17 Nov 2016	Shamoon 2 wiping set for 20:45; further waves 29 Nov 2016 and 23 Jan 2017	Attack	[19] [20]	Confirmed
6 and 17 Dec 2016	Ukrainian Ministry of Finance and Treasury attack; Industroyer cuts Kyiv power about an hour	Attack	[28]	Confirmed
29 Dec 2016	JAR-16-20296A	Response	[46]	Confirmed
14 Mar 2017	MS17-010	Defense	[36]	Confirmed
3 Apr to 3 May 2017	GRU spearphishing of the French campaign ahead of the 7 May vote; leaks by unidentified individuals from 3 and 5 May	Destabilization	[28]	Confirmed
15 Apr 2017	Shadow Brokers exploit release	Blowback	[14] [37]	Confirmed
12 May 2017	WannaCry	Attack	[14] [38]	Confirmed
27 Jun 2017	NotPetya through M.E.Doc (TA17-181A, 1 Jul 2017)	Attack	[45]	Confirmed

Date	Event	Category	Source	Grade
19 Dec 2017	WannaCry attributed to North Korea by the US and five partners	Response	[39] [44]	Confirmed
15 Feb 2018	White House attributes NotPetya to the Russian military	Response	[29]	Confirmed
16 Feb 2018	Prigozhin charged	Response	[34]	Confirmed
8 Jun 2018	Park Jin Hyok complaint signed (unsealed September)	Response	[14]	Confirmed
13 Jul 2018	Twelve GRU officers indicted	Response	[31] [32]	Confirmed
2020	*The Hacker and the State* published	Book	[54]	Confirmed
15 Oct 2020	Six Unit 74455 officers indicted	Response	[28] [42]	Confirmed
8 Dec 2020	Further warrant for Park Jin Hyok	Response	[17]	Confirmed

Part 7: attribution and the state response

Operation	Who said so	When	Instrument	Source
APT1	Mandiant: PLA Unit 61398	Feb 2013	Vendor report	[5]
Unit 61398 economic espionage	US grand jury	1 May 2014	Indictment of five officers	[7]
Sony Pictures	FBI; the President	19 Dec 2014	Public attribution	[12] [15]
Sony Pictures	Treasury	2 Jan 2015	Executive Order and designations	[16]
Commercial IP theft	US and Chinese governments	25 Sep 2015	Bilateral commitment	[6]
Party network intrusions	US government joint analysis report	29 Dec 2016	Joint analysis report naming two Russian services	[46]
WannaCry	UK, US and five partners	19 Dec 2017	Coalition attribution	[39] [44]
NotPetya	White House	15 Feb 2018	Public attribution to the Russian military	[29]
Internet Research Agency	US	16 Feb 2018	Criminal charge	[34]
Sony, Bangladesh Bank, WannaCry	US	8 Jun 2018	Criminal complaint	[14]
2016 election hacking	US grand jury	13 Jul 2018	Indictment of twelve officers	[31] [32]
Ukraine, NotPetya, France, Olympics	US grand jury	15 Oct 2020	Indictment of six officers	[28] [42]
Shamoon	No government attribution among the sources opened; Kaspersky's assessment and ATT&CK's description only	2012 to 2024	Vendor and knowledge-base text	[20] [21]
Belgacom	No government statement; journalism on leaked documents	2014 and 2018	Press	[9] [10]

Three patterns stand out (**Inferred**, this study's reading of the table). First, the time to attribution shortened when the impact was public: under four weeks for Sony, months for WannaCry, years for quiet espionage. Second, criminal charges against named officers, first used in 2014 [7], became the main instrument from 2018 [14] [31] [34]. Third, operations whose perpetrator state never acknowledged them and no government attributed, such as Belgacom, are known only through leaked documents and journalism [9] [10], which is the shaping half of the book's argument seen from the outside.

Part 8: the defender view

8.1 What the advisories asked for

Advisory	Date	Core advice	Source
TA14-353A (Sony toolkit)	19 Dec 2014	Daily backups with offline copies; limit admin privileges and credential caching; VLAN segmentation isolating critical networks; two-factor for privileged and remote access; emergency communication plans and spare hardware for critical systems	[13]
TA17-132A (WannaCry)	12 May 2017, rev. 7 Jun 2018	Patch MS17-010; disable SMBv1 and block SMB at boundaries; keep offline, tested backups	[38]
TA17-181A (NotPetya)	1 Jul 2017	Recovery may be impossible even after payment; the spread used stolen credentials, PsExec, WMIC and SMB exploits	[45]
AA22-057A (destructive malware)	26 Feb 2022, rev. 28 Apr 2022	MFA; segmentation; least privilege for service accounts; staged update deployment with integrity checks; configuration backups and restoration media; an exercised incident response plan	[47]

AA22-057A was written for the 2022 wipers (WhisperGate, HermeticWiper, IsaacWiper, CaddyWiper) and does not mention NotPetya [47] (**Confirmed**). That its advice so closely matches the 2014 alert is this study's observation (**Inferred**).

8.2 Lessons by case

- **OPM: contractor credentials and missing MFA.** The intrusion ran on a contractor's credential and domain administrator rights [2], in an agency with one percent PIV coverage [2]. Defender action: phishing-resistant MFA for every privileged and remote account, and contractor access reviewed as rigorously as staff access.
- **OPM: watching an intruder has a price.** OPM monitored the first actor for about two months while documentation was taken [2] (**Confirmed**). The sources here do not settle whether monitoring was the right call; the lesson is to decide containment criteria in advance (**Inferred**).
- **APT1: the commodity toolset.** Public credential dumpers and pass-the-hash carried a state operation [5]. Defender action: credential hardening, limits on cached credentials, and detection for LSASS and SAM access (D3FEND Credential Hardening).
- **Sony and Shamoon: credentials, admin shares, raw disk.** Brute-forced or stolen credentials, SMB admin shares and commercial raw-disk drivers (signed, in Shamoon's case) [13] [18] [19]. Defender action: least privilege, block lateral SMB between workstations, and watch for new services and raw-disk driver loads; keep offline backups.
- **Shamoon 2: the timing.** The wipe was set for the end of the work week [19]. Defender action: make sure out-of-hours detection and response actually exist (**Inferred**).
- **The DNC: remediation is not removal.** A Linux X-Agent survived remediation for months [32]. Defender action: hunt across every platform after remediation, including Linux servers, and verify eviction.
- **Bangladesh Bank: protect the payment environment and its records.** The attackers reached SWIFT Alliance Access by lateral movement [14], then altered the database and printed confirmations [35].

Defender action: isolate payment systems, reconcile through an independent channel, and monitor integrity of the software and its database.

- **WannaCry: the patch gap.** Fifty-nine days separated MS17-010 from WannaCry [36] [14]. Defender action: prioritize remotely exploitable flaws in internal services; KEV listing came years later [41], so do not wait for it.

8.3 Library corrections

1. **Regin proxy mapping.** The library's `/mitre/software/S0019.md` maps T1090.002 External Proxy, while Kaspersky describes internal relay drones, which fits T1090.001 Internal Proxy [11] [53] (**Confirmed** for both texts). The page is generated from ATT&CK data, so the fix is a note, not a hand edit.
2. **Operation Aurora attribution.** `NOTABLE_INCIDENTS.md` line 84 attributes Operation Aurora to "APT10 / Comment Crew (Chinese PLA Unit 61398)", which merges distinct groups [54] (**Inferred**; a primary check is still needed before the line is changed).
3. **Shamoon.** `MALWARE_FAMILIES.md` lines 440 and 568 attribute Shamoon to "APT33 / Iranian IRGC", which goes beyond ATT&CK, since ATT&CK lists no group for S0140 [21]; the fix is to state the Cutting Sword of Justice claim and the absence of an ATT&CK group [21] (**Confirmed**).
4. **Book cross-reference.** The book's entry in `CYBERSECURITY_BOOK_LIST.md` (line 1136) [54] can link this study.

Part 9: MITRE mappings

This Part binds the record to MITRE ATT&CK v20.0, CAPEC, CWE and D3FEND. Every technique id was checked against the library's `data/attack/technique_profiles.jsonl` and `superseded_by.jsonl`, and every linked page was checked to exist in the library's `mitre/` tree on 3 November 2026 [52] [53]. Revoked T1070.001 Clear Windows Event Logs appears under its v20.0 successor T1685.005 [52]. Tactics are the v20.0 tactics in the library's data. ATT&CK for ICS rows belong to the Stuxnet and Sandworm studies and are not repeated here.

Mapping grades: **Confirmed** when a primary describes the behaviour the technique names; **ATT&CK** when ATT&CK records the technique for the group or software but not for the dated event; **Reported** when only journalism describes it; **Inferred** for this study's judgment calls.

9.1 Objects

Object	ATT&CK id	Library page	Relationship in this study
Group	APT1, G0006	/mitre/groups/G0006.md	Mandiant's APT1; assessed as PLA Unit 61398 [5]
Group	APT28, G0007	/mitre/groups/G0007.md	GRU Unit 26165; 2016 election intrusions [24] [46]
Group	APT29, G0016	/mitre/groups/G0016.md	Party network intrusion from summer 2015 [46]
Group	Lazarus Group, G0032	/mitre/groups/G0032.md	Reportedly responsible for Sony 2014; WannaCry per the UK [22] [39]
Group	Sandworm Team, G0034	/mitre/groups/G0034.md	GRU Unit 74455; Ukraine, NotPetya, French campaign [28]
Group	APT38, G0082	/mitre/groups/G0082.md	Credited with the 2016 Bangladesh Bank heist [23]
Software	Mimikatz, S0002	/mitre/software/S0002.md	In APT1's toolset [5]
Software	Regin, S0019	/mitre/software/S0019.md	The platform [11]; the Belgacom link is Reported [9]
Software	CHOPSTICK (X-Agent), S0023	/mitre/software/S0023.md	DCCC and DNC implant [32]
Software	XTunnel, S0117	/mitre/software/S0117.md	Exfiltration tunnel [32]
Software	CozyCar S0046, SeaDuke S0053	/mitre/software/S0046.md, /mitre/software/S0053.md	APT29 software in the library's data; not named in the JAR text used here [52]
Software	Shamoon, S0140	/mitre/software/S0140.md	2012 and 2016 wipers; no group in ATT&CK [21]
Software	RawDisk, S0364	/mitre/software/S0364.md	Raw-disk driver in Shamoon; linked to Lazarus in the library's data [19] [52]
Software	StoneDrill, S0380	/mitre/software/S0380.md	Compared with Shamoon by Kaspersky [20]
Software	WannaCry, S0366	/mitre/software/S0366.md	Lazarus Group in the library's data [52]
Software	NotPetya S0368, Olympic Destroyer S0365, KillDisk S0607, BlackEnergy S0089, Industroyer S0604	S0368, S0365, S0607, S0089, S0604	Summary only; home is the Sandworm study [28] [52]
Software	Stuxnet, S0603	/mitre/software/S0603.md	Summary only; home is Stuxnet [25]
Campaign	2015 Ukraine Electric Power Attack, C0028; 2016 Ukraine Electric Power Attack, C0025	C0028, C0025	Summary only [26] [52]

Object	ATT&CK id	Library page	Relationship in this study
Campaign	none	none	The library's campaign data has no object for Sony 2014, Bangladesh Bank, Shamoon, WannaCry, NotPetya or the 2016 DNC intrusions [52]
Not linked	DYEPACK, WhiskeyAlfa, WhiskeyBravo, WhiskeyDelta, SHARPKNOT, NESTEGG, MACKTRUCK, Destover	none	Named in procedure text or the complaint; no ATT&CK software id [14] [22] [23]

9.2 Espionage: OPM, APT1, Belgacom and Regin

ID	Name	Tactic(s)	Dated event or report	Source	Grade
T1078.002	Valid Accounts: Domain Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	OPM 2014: contractor credential, then domain administrator	[2]	Confirmed
T1021.001	Remote Services: Remote Desktop Protocol	Lateral Movement	OPM June 2014	[3]	Confirmed
T1583.001	Acquire Infrastructure: Domains	Resource Development	opmsecurity.org, April 2014	[3]	Confirmed
T1566.001	Phishing: Spearphishing Attachment	Initial Access	APT1 ZIP attachments, 2006 to 2013	[5]	Confirmed
T1566.002	Phishing: Spearphishing Link	Initial Access	APT1 linked ZIP files	[5]	Confirmed
T1071.001	Application Layer Protocol: Web Protocols	Command and Control	APT1 WEBC2; Regin HTTP/HTTPS	[5] [11]	Confirmed
T1003.001	OS Credential Dumping: LSASS Memory	Credential Access	APT1 lslsass, mimikatz	[5]	Confirmed
T1003.002	OS Credential Dumping: Security Account Manager	Credential Access	APT1 gsecdump, pwdump7, fgdump	[5]	Confirmed
T1003.004	OS Credential Dumping: LSA Secrets	Credential Access	APT1 gsecdump	[5]	Confirmed
T1003.005	OS Credential Dumping: Cached Domain Credentials	Credential Access	APT1 cachedump	[5]	Confirmed
T1550.002	Use Alternate Authentication Material: Pass the Hash	Lateral Movement	APT1 pass-the-hash toolkit	[5]	Confirmed
T1560	Archive Collected Data	Collection	APT1 compressed archives	[5]	Confirmed
T1070.004	Indicator Removal: File Deletion	Stealth	APT1 archives deleted after theft	[5]	Confirmed
T1114	Email Collection	Collection	APT1 GETMAIL, MAPIGET	[5]	Confirmed
T1090	Proxy	Command and Control	APT1 HTRAN, 767 observed uses	[5]	Confirmed
T1189	Drive-by Compromise	Initial Access	Belgacom, Quantum Insert to a fake LinkedIn page, 2010 to 2011	[9]	Reported
T1036	Masquerading	Stealth	Belgacom malware disguised as Microsoft software	[10]	Reported
T1074	Data Staged	Collection	Belgacom encrypted, compressed containers	[10]	Reported
T1564.004	Hide Artifacts: NTFS File Attributes	Stealth	Regin stages in Extended Attributes, Nov 2014 report	[11]	Confirmed (Regin)

ID	Name	Tactic(s)	Dated event or report	Source	Grade
T1112	Modify Registry	Defense Impairment, Persistence	Regin stages in the registry	[11]	Confirmed (Regin)
T1564.005	Hide Artifacts: Hidden File System	Stealth	Regin encrypted virtual file systems	[11]	Confirmed (Regin)
T1021.002	Remote Services: SMB/Windows Admin Shares	Lateral Movement	Regin spread through admin shares	[11]	Confirmed (Regin)
T1095	Non-Application Layer Protocol	Command and Control	Regin ICMP raw-socket C2	[11]	Confirmed (Regin)
T1090.001	Proxy: Internal Proxy	Command and Control	Regin internal relay drones	[11]	Confirmed (Regin)

9.3 Attack: Sony Pictures 2014 and Shamoon 2012 and 2016

ID	Name	Tactic(s)	Dated event or report	Source	Grade
T1595	Active Scanning	Reconnaissance	Sony: North Korean IP scans an SPE web server, 22 Sep 2014	[14]	Confirmed
T1585.002	Establish Accounts: Email Accounts	Resource Development	Sony: `bluehotrain@hotmail.com`; "Frank David", 21 Nov 2014	[14]	Confirmed
T1585.001	Establish Accounts: Social Media Accounts	Resource Development	Sony: fake Facebook personas, Sep 2014	[14]	Confirmed
T1566.002	Phishing: Spearphishing Link	Initial Access	Sony: `1drv.ms` link, 25 Sep 2014	[14]	Confirmed
T1204.002	User Execution: Malicious File	Execution	Sony: Adobe Flash-named executable; execution is the affiant's assessment	[14]	Inferred (the affiant's assessment)
T1110.001	Brute Force: Password Guessing	Credential Access	Sony: SMB worm brute force	[13]	Confirmed (TA14-353A); Inferred (Sony)
T1021.002	Remote Services: SMB/Windows Admin Shares	Lateral Movement	Sony: `admin$`, `shared$`; Shamoon 2: `NetUseAdd`	[13] [19]	Confirmed
T1047	Windows Management Instrumentation	Execution	Sony: WMIC remote start	[13]	Confirmed (TA14-353A); Inferred (Sony)
T1070.006	Indicator Removal: Timestomp	Stealth	Sony: timestamp matched to `calc.exe`; ATT&CK also lists it for Shamoon	[13] [21]	Confirmed (TA14-353A); Inferred (Sony)
T1543.003	Create or Modify System Process: Windows Service	Persistence, Privilege Escalation	Sony: `WinsSchMgmt`; Shamoon 2: `ntssrv`	[13] [19]	Confirmed
T1090	Proxy	Command and Control	Sony: proxy tool on TCP 443	[13]	Confirmed (TA14-353A); Inferred (Sony)
T1571	Non-Standard Port	Command and Control	Sony: C2 on 8080 and 8000, implant on 195 and 444	[13]	Confirmed (TA14-353A); Inferred (Sony)
T1489	Service Stop	Impact	Sony: the Exchange information store service stopped	[13]	Confirmed (TA14-353A); Inferred (Sony)
T1561.002	Disk Wipe: Disk Structure Wipe	Impact	Sony MBR overwrite, Nov 2014; Shamoon RawDisk wipe, Aug 2012 and Nov 2016	[13] [14] [18] [19]	Confirmed
T1561.001	Disk Wipe: Disk Content Wipe	Impact	Lazarus WhiskeyAlfa family; Sony not named in the procedure	[22]	ATT&CK

ID	Name	Tactic(s)	Dated event or report	Source	Grade
T1485	Data Destruction	Impact	Sony: files and MFT overwritten; Shamoon 2: files overwritten with an image	[14] [19]	Confirmed
T1491.001	Defacement: Internal Defacement	Impact	Sony: "Hacked By #GOP", 24 Nov 2014	[14]	Confirmed
T1529	System Shutdown/Reboot	Impact	Sony: reboot after 120 minutes; Shamoon 2: forced immediate reboot	[13] [19]	Confirmed
T1078.002	Valid Accounts: Domain Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Shamoon 2: stolen admin credentials hard-coded	[19]	Confirmed
T1112	Modify Registry	Defense Impairment, Persistence	Shamoon 2: `LocalAccountTokenFilterPolicy`	[19]	Confirmed
T1548.002	Abuse Elevation Control Mechanism: Bypass User Account Control	Privilege Escalation	Shamoon 2: UAC remote restriction disabled; ATT&CK maps it for S0140	[19] [21]	Confirmed
T1569.002	System Services: Service Execution	Execution	Shamoon 2: the service runs the payload	[19]	Confirmed
T1036.004	Masquerading: Masquerade Task or Service	Stealth	Shamoon 2: "Microsoft Network Realtime Inspection Service"	[19]	Confirmed
T1053.005	Scheduled Task/Job: Scheduled Task	Execution, Persistence, Privilege Escalation	Shamoon 2: `NetScheduleJobAdd`	[19]	Confirmed
T1071.001	Application Layer Protocol: Web Protocols	Command and Control	Shamoon 2: HTTP C2 with `shinu`	[19]	Confirmed
T1105	Ingress Tool Transfer	Command and Control	Shamoon 2: download and execute	[19]	Confirmed
T1082	System Information Discovery	Discovery	Shamoon 2: OS version and keyboard layout	[19]	Confirmed
T1012	Query Registry	Discovery	Shamoon 2: boot device registry keys	[19]	Confirmed
T1486	Data Encrypted for Impact	Impact	Shamoon 2: E mode RC4, a capability (the analysed sample used F)	[19]	Confirmed (capability)
T1570	Lateral Tool Transfer	Lateral Movement	Shamoon, as ATT&CK records for S0140	[21]	ATT&CK

T1110 Brute Force and T1047 also appear in G0032's mapping, but ATT&CK does not tie them to Sony; the Sony rows above rest on TA14-353A [13] [22] (**Inferred** for the Sony link at the group level).

9.4 Destabilization: the 2016 US election and the 2017 French campaign

ID	Name	Tactic(s)	Dated event or report	Source	Grade
T1598.003	Phishing for Information: Spearphishing Link	Reconnaissance	Spoofed Google notice to the campaign chairman, 19 Mar 2016; APT28 fake webmail page, spring 2016	[32] [46]	Confirmed
T1590	Gather Victim Network Information	Reconnaissance	DNC and DCCC IP queries, 15 Mar and 7 Apr 2016	[32]	Confirmed
T1593	Search Open Websites/Domains	Reconnaissance	Open-source research on the networks	[32]	Confirmed
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	DNC entered with DCCC credentials, 18 Apr 2016	[32] [46]	Confirmed
T1056.001	Input Capture: Keylogging	Collection, Credential Access	X-Agent on DCCC computers, Apr to Jun 2016	[32]	Confirmed
T1113	Screen Capture	Collection	X-Agent screenshots	[32]	Confirmed
T1090.002	Proxy: External Proxy	Command and Control	Overseas relay to the AMS panel	[32]	Confirmed
T1560	Archive Collected Data	Collection	Documents compressed with a public tool	[32]	Confirmed
T1114.002	Email Collection: Remote Email Collection	Collection	DNC Exchange server, 25 May to 1 Jun 2016; APT29 email exfiltration	[32] [46]	Confirmed
T1685.005	Clear Windows Event Logs	Defense Impairment	DNC event logs cleared, 13 May 2016 (revoked T1070.001)	[32] [52]	Confirmed
T1070.004	Indicator Removal: File Deletion	Stealth	CCleaner on the DCCC network, 1 Jun; AMS logs deleted, 20 Jun 2016	[32]	Confirmed
T1583.001	Acquire Infrastructure: Domains	Resource Development	actblues.com, 14 Jun 2016; DCLeaks.com	[31] [32]	Confirmed
T1585.001	Establish Accounts: Social Media Accounts	Resource Development	DCLeaks promotion; Guccifer 2.0, 15 Jun 2016; GRU account offering purported documents of En Marche!, 12 to 26 Apr 2017	[31] [28]	Confirmed
T1566.002	Phishing: Spearphishing Link	Initial Access	APT29 link campaign to more than 1,000 recipients, summer 2015	[46]	Confirmed
T1566.001	Phishing: Spearphishing Attachment	Initial Access	Seven campaigns against En Marche!, other politicians and local government addresses, 3 Apr to 3 May 2017; the malware-laced document, 21 Apr 2017	[28]	Confirmed
T1585.002	Establish Accounts: Email Accounts	Resource Development	Account mimicking Macron's press secretary, 21 Apr 2017	[28]	Confirmed

Inferred rows for this Part: T1041 Exfiltration Over C2 Channel and T1572 Protocol Tunneling for X-Tunnel [32]; T1190 Exploit Public-Facing Application for the state board of elections website, July 2016 [32]; T1087.002 Account Discovery: Domain Account for APT29's Active Directory enumeration, which G0016's

mapping does not list [46] [52]; T1585.001 for the Internet Research Agency's personas [34]; and the T1566.002 half of the French campaign split [28] (all **Inferred**).

9.5 Money and blowback: Bangladesh Bank and WannaCry

ID	Name	Tactic(s)	Dated event or report	Source	Grade
T1594	Search Victim-Owned Websites	Reconnaissance	Bangladeshi bank websites visited, 7 to 8 Oct 2014	[14]	Confirmed
T1566.002	Phishing: Spearphishing Link	Initial Access	`Resume.zip` link from 29 Jan 2015	[14]	Confirmed
T1543.003	Create or Modify System Process: Windows Service	Persistence, Privilege Escalation	NESTEGG service; WannaCry `mssecsvc2.0`	[14] [38]	Confirmed
T1070.004	Indicator Removal: File Deletion	Stealth	NESTEGG dropper securely erased	[14]	Confirmed
T1001.003	Data Obfuscation: Protocol or Service Impersonation	Command and Control	MACKTRUCK fake TLS over 443	[14]	Confirmed
T1565.003	Data Manipulation: Runtime Data Manipulation	Impact	`liboradb.dll` patched in memory, analysis of 25 Apr 2016	[35]	Confirmed
T1565.001	Data Manipulation: Stored Data Manipulation	Impact	SQL `DELETE` against `SAAOWNER`; altered confirmations	[35] [14]	Confirmed
T1565.002	Data Manipulation: Transmitted Data Manipulation	Impact	DYEPACK, as ATT&CK records for APT38	[23]	ATT&CK
T1657	Financial Theft	Impact	About $81 million, Feb 2016	[14]	Confirmed
T1685.005	Clear Windows Event Logs	Defense Impairment	APT38 evidence destruction	[23]	ATT&CK
T1210	Exploitation of Remote Services	Lateral Movement	WannaCry through CVE-2017-0144, 12 May 2017	[14] [38]	Confirmed
T1016	System Network Configuration Discovery	Discovery	WannaCry derives the LAN range	[14]	Confirmed
T1486	Data Encrypted for Impact	Impact	WannaCry encryption; payment did not decrypt	[14]	Confirmed
T1490	Inhibit System Recovery	Impact	WannaCry (S0366)	[52]	ATT&CK
T1489	Service Stop	Impact	WannaCry (S0366)	[52]	ATT&CK
T1570	Lateral Tool Transfer	Lateral Movement	WannaCry (S0366)	[52]	ATT&CK
T1090.003	Proxy: Multi-hop Proxy	Command and Control	WannaCry (S0366)	[52]	ATT&CK
T1588.005	Obtain Capabilities: Exploits	Resource Development	Shadow Brokers release used by the WannaCry operators, 15 Apr 2017	[14]	Inferred

9.6 CVE, CWE and CAPEC

CVE. MS17-010 fixed CVE-2017-0143 to CVE-2017-0148 [36]; CVE-2017-0144 is the flaw WannaCry used [14], and KEV added it on 10 February 2022 (CVE-2017-0143 on 3 November 2021) [41] (**Confirmed**). No CVE is named in the Sony, Shamoon, OPM, Bangladesh Bank or election records opened. See the CVE Reference.

CWE. NVD lists `NVD-CWE-noinfo` for CVE-2017-0144 [40], so this study assigns no CWE (**Confirmed**).

CAPEC. These are the CAPEC entries that the library's data links to the mapped techniques; each has a library page [52] (**Confirmed** for the links; the fit is ATT&CK's).

CAPEC	Name	Via technique	Case
CAPEC-163	Spear Phishing	`T1566.001`, `T1566.002`, `T1598.003`	APT1, Sony, DNC, Bangladesh Bank, France
CAPEC-560	Use of Known Domain Credentials	`T1078`	DNC
CAPEC-561	Windows Admin Shares with Stolen Credentials	`T1021.002`	Sony, Shamoon 2, Regin
CAPEC-644	Use of Captured Hashes (Pass The Hash)	`T1550.002`	APT1
CAPEC-49	Password Brute Forcing	`T1110.001`	Sony
CAPEC-169	Footprinting	`T1595`	Sony
CAPEC-309	Network Topology Mapping	`T1590`, `T1016`	DNC, WannaCry
CAPEC-555	Remote Services with Stolen Credentials	`T1114.002`	DNC
CAPEC-568	Capture Credentials via Keylogger	`T1056.001`	DNC
CAPEC-648	Collect Data from Screen Capture	`T1113`	DNC
CAPEC-478	Modification of Windows Service Configuration	`T1543.003`	Sony, Shamoon 2, Bangladesh Bank, WannaCry
CAPEC-504	Task Impersonation	`T1036.004`	Shamoon 2
CAPEC-203	Manipulate Registry Information	`T1112`	Shamoon 2, Regin
CAPEC-647	Collect Data from Registries	`T1012`	Shamoon 2
CAPEC-465	Transparent Proxy Abuse	`T1090.001`	Regin

See the CAPEC Reference and CWE Reference.

9.7 D3FEND

The library's `data/attack/technique_to_d3fend.jsonl` maps these countermeasures to techniques above, and each has a library page [52] [53] (**Confirmed** for the rows).

D3FEND countermeasure	Techniques it counters (library rows)	Where it meets the record
Disk Partitioning	`T1561.001`, `T1561.002`	Sony and Shamoon MBR wipes
Restore Configuration	`T1490`	WannaCry recovery
Restore Software	`T1490`, `T1489`	Recovery after WannaCry and the Sony service stops
Software Update	`T1490`, `T1489`	MS17-010 [36]
Network Traffic Filtering	`T1210`, `T1021.001`, `T1571`, `T1095`	Blocking SMB at boundaries [38]; OPM's RDP session; Sony's odd ports
Outbound Traffic Filtering	`T1571`, `T1095`, `T1090.002`, `T1572`	Sony C2 ports; the X-Agent relay and X-Tunnel
Credential Hardening	`T1003.005`, `T1110.001`	APT1 cachedump; Sony's SMB worm
Multi-factor Authentication	`T1003.005`, `T1110.001`	TA14-353A two-factor advice against the Sony-era brute force [13]; OPM's missing MFA is related advice, not a library row for its T1078.002 [2] (**Inferred**)
Domain Account Monitoring	`T1078.002`, `T1087.002`	OPM domain administrator; Shamoon 2 credentials; APT29 AD enumeration
Account Locking	`T1078`, `T1078.002`	Locking stolen accounts once found
User Account Permissions	`T1078`, `T1078.002`	Least privilege [13] [47]
Remote Terminal Session Detection	`T1021.001`	OPM's June 2014 RDP session
Scheduled Job Analysis	`T1036.004`	Shamoon 2's disguised service and job
Content Filtering	`T1566.001`, `T1566.002`	The phishing in every case

`T1485` Data Destruction and `T1021.002` have no D3FEND rows in the library, and the library has no page for file backup or boot-record analysis [52] (**Confirmed**). The offline-backup advice of every advisory [13] [38] [47] therefore has no D3FEND counterpart in the library today. See the D3FEND Reference.

9.8 Navigator layer

- Enterprise: `navigator/library-layers/hacker-and-the-state-cases.json` (open in Navigator), domain `enterprise-attack`, ATT&CK version 20. It carries the 72 techniques of Parts 9.2 to 9.5, each shown under all its tactics, with a comment naming the case, the dated event and the source numbers of this study. It is listed in the Navigator layer index.

Scores mean only how the mapping is graded. 100: a government, court or vendor primary describes the behaviour. 60: ATT&CK records it for the group or software, not for the dated event. 40: Reported only. 30: Inferred. The layer is a curated mapping, not an official MITRE mapping.

Cross-cutting themes

- **Shaping is quiet and long.** OPM's nearly three years from first access to public notice [3], APT1's average of 356 days [5] and the months of Bangladesh Bank reconnaissance [14] fit the book's picture of constant, peacetime competition [48] (**Inferred**).
- **Signals came from the defenders.** Indictments [7] [28] [32], sanctions [16] and coalition attributions [44] were the public messages; the hacks themselves were deniable and hard to read (**Inferred**).
- **The same few techniques carried every category.** Phishing, stolen credentials, admin shares and services appear in espionage (APT1, OPM), attack (Sony, Shamoon), destabilization (DNC, France) and theft (Bangladesh Bank) alike (Part 9). The category is set by the operator's goal, not the toolset (**Inferred**).
- **Destruction is now a tool of statecraft.** Sony in 2014 [12], the Ukrainian grid in 2015 and 2016 [27] [28] and NotPetya and WannaCry in 2017 [29] [44], each attributed by a government to a state, show destructive malware used against companies and infrastructure in peacetime; Shamoon (2012 and 2016) fits the pattern but no government source opened here attributes it [20] [21] (**Inferred**).
- **Overstated and understated.** Overstated: the certainty of some attributions (Shamoon has no ATT&CK group [21]; Belgacom has no government attribution [9] [10]) and the idea that the NSA provenance of the WannaCry exploit is officially confirmed [43] [44]. Understated: how ordinary the failures were (missing MFA [2], an unpatched SMB flaw [36], a surviving Linux implant [32]), and how much the public record owes to criminal filings that most defenders never read (**Inferred**).

Sources

#	Source	URL	Opened	Grade
1	House Committee on Oversight and Government Reform, majority staff report page, "The OPM Data Breach", 7 Sep 2016	https://oversight.house.gov/report/opm-data-breach-government-jeopardized-national-security-generation/	3 Nov 2026	Confirmed
2	Same report, full text (PDF; pages i to vii read)	https://oversight.house.gov/wp-content/uploads/2016/09/The-OPM-Data-Breach-How-the-Government-Jeopardized-Our-National-Security-for-More-than-a-Generation.pdf	3 Nov 2026	Confirmed
3	Same committee, "Timeline of Key Events" (PDF)	https://oversight.house.gov/wp-content/uploads/2016/09/Timeline-of-Key-Events-.pdf	3 Nov 2026	Confirmed
4	Privacy and Civil Liberties Oversight Board, report on the Section 702 program, 2 Jul 2014	https://documents.pclob.gov/prod/Documents/OversightReport/823399ae-92ea-447a-ab60-0da28b555437/702-Report-2.pdf	3 Nov 2026	Confirmed
5	Mandiant, "APT1: Exposing One of China's Cyber Espionage Units", Feb 2013 (university course copy)	https://cs.brown.edu/courses/cs180/sources/2013_Mandiant_APT1_Report.pdf	3 Nov 2026	Confirmed
6	The White House (archived), fact sheet on President Xi Jinping's state visit, 25 Sep 2015	https://obamawhitehouse.archives.gov/the-press-office/2015/09/25/fact-sheet-president-xi-jinpings-state-visit-united-states	3 Nov 2026	Confirmed
7	FBI Most Wanted, Wang Dong (PLA Unit 61398 indictment)	https://www.fbi.gov/wanted/cyber/wang-dong	3 Nov 2026	Confirmed
8	NIST, "NIST Removes Cryptography Algorithm from Random Number Generator Recommendations", 21 Apr 2014	https://www.nist.gov/node/395286	3 Nov 2026	Confirmed
9	Ryan Gallagher, *The Intercept*, "Operation Socialist", 13 Dec 2014	https://theintercept.com/2014/12/13/belgacom-hack-gchq-inside-story/	3 Nov 2026	Reported
10	Ryan Gallagher, *The Intercept* with *de Volkskrant*, "How U.K. Spies Hacked a European Ally and Got Away With It", 17 Feb 2018	https://theintercept.com/2018/02/17/gchq-belgacom-investigation-europe-hack/	3 Nov 2026	Reported
11	Kaspersky GReAT, "Regin: nation-state ownage of GSM networks", 24 Nov 2014	https://securelist.com/regin-nation-state-ownage-of-gsm-networks/67741/	3 Nov 2026	Confirmed
12	FBI, "Update on Sony Investigation", 19 Dec 2014	https://www.fbi.gov/news/press-releases/update-on-sony-investigation	3 Nov 2026	Confirmed
13	US-CERT/CISA Alert TA14-353A, "Targeted Destructive Malware", 19 Dec 2014	https://www.cisa.gov/news-events/alerts/2014/12/19/targeted-destructive-malware	3 Nov 2026	Confirmed
14	Criminal complaint, United States v. Park Jin Hyok, C.D. Cal. 18-1479, signed 8 Jun 2018 (PDF)	https://www.justice.gov/opa/press-release/file/1092091/download	3 Nov 2026	Confirmed
15	The White House (archived), the President's year-end press conference, 19 Dec 2014	https://obamawhitehouse.archives.gov/the-press-office/2014/12/19/remarks-president-year-end-press-conference	3 Nov 2026	Confirmed
16	US Treasury press release jl9733, 2 Jan 2015	https://home.treasury.gov/news/press-releases/jl9733	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
17	FBI Most Wanted, Park Jin Hyok	https://www.fbi.gov/wanted/cyber/park-jin-hyok	3 Nov 2026	Confirmed
18	Kaspersky GReAT, "Shamoon the Wiper: Copycats at Work", 16 Aug 2012	https://securelist.com/shamoon-the-wiper-copycats-at-work/57854/	3 Nov 2026	Confirmed
19	Palo Alto Networks Unit 42, "Shamoon 2: Return of the Disttrack Wiper", 30 Nov 2016	https://unit42.paloaltonetworks.com/unit42-shamoon-2-return-disttrack-wiper/	3 Nov 2026	Confirmed
20	Kaspersky, "From Shamoon to StoneDrill", Mar 2017	https://securelist.com/from-shamoon-to-stonedrill/77725/	3 Nov 2026	Confirmed
21	MITRE ATT&CK, S0140 Shamoon	https://attack.mitre.org/software/S0140/	3 Nov 2026	Confirmed
22	MITRE ATT&CK, G0032 Lazarus Group	https://attack.mitre.org/groups/G0032/	3 Nov 2026	Confirmed
23	MITRE ATT&CK, G0082 APT38	https://attack.mitre.org/groups/G0082/	3 Nov 2026	Confirmed
24	MITRE ATT&CK, G0007 APT28	https://attack.mitre.org/groups/G0007/	3 Nov 2026	Confirmed
25	MITRE ATT&CK, S0603 Stuxnet	https://attack.mitre.org/software/S0603/	3 Nov 2026	Confirmed
26	MITRE ATT&CK, C0028 2015 Ukraine Electric Power Attack (and C0025)	https://attack.mitre.org/campaigns/C0028/	3 Nov 2026	Confirmed
27	ICS-CERT alert IR-ALERT-H-16-056-01, Ukraine (updated 2021)	https://www.cisa.gov/news-events/ics-alerts/ir-alert-h-16-056-01	3 Nov 2026	Confirmed
28	Indictment, United States v. Andrienko et al., W.D. Pa., 2020 (PDF)	https://www.justice.gov/opa/press-release/file/1328521/download	3 Nov 2026	Confirmed
29	The White House (archived), statement from the Press Secretary on NotPetya, 15 Feb 2018	https://trumpwhitehouse.archives.gov/briefings-statements/statement-press-secretary-25/	3 Nov 2026	Confirmed
30	CISA Alert, "CrashOverride Malware" (updated 2021)	https://www.cisa.gov/news-events/alerts/2017/06/12/crashoverride-malware	3 Nov 2026	Confirmed
31	DOJ release, "Grand Jury Indicts 12 Russian Intelligence Officers", 13 Jul 2018 (Wayback capture)	https://web.archive.org/web/20250102185838/https://www.justice.gov/opa/pr/grand-jury-indicts-12-russian-intelligence-officers-hacking-offenses-related-2016-election	3 Nov 2026	Confirmed
32	Indictment, United States v. Netyksho et al., D.D.C. 1:18-cr-00215, 13 Jul 2018 (PDF copy)	https://int.nyt.com/data/documenthelper/80-netyksho-et-al-indictment/ba0521c1eef869deecbe/optimized/full.pdf	3 Nov 2026	Confirmed
33	FBI Most Wanted, "Russian Interference in 2016 U.S. Elections"	https://www.fbi.gov/wanted/cyber/russian-interference-in-2016-u-s-elections	3 Nov 2026	Confirmed
34	FBI Most Wanted, Yevgeniy Viktorovich Prigozhin	https://www.fbi.gov/wanted/counterintelligence/yevgeniy-viktorovich-prigozhin	3 Nov 2026	Confirmed
35	BAE Systems Threat Research, "Two bytes to $951m", 25 Apr 2016	https://baesystemsai.blogspot.com/2016/04/two-bytes-to-951m.html	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
36	Microsoft Security Bulletin MS17-010, 14 Mar 2017	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010	3 Nov 2026	Confirmed
37	MSRC blog, "Protecting customers and evaluating risk", 15 Apr 2017	https://www.microsoft.com/en-us/msrc/blog/2017/04/protecting-customers-and-evaluating-risk	3 Nov 2026	Confirmed
38	US-CERT/CISA Alert TA17-132A, WannaCry, 12 May 2017 (rev. 7 Jun 2018)	https://www.cisa.gov/news-events/alerts/2017/05/12/indicators-associated-wannacry-ransomware	3 Nov 2026	Confirmed
39	UK Foreign Office, "Foreign Office Minister condemns North Korean actor for WannaCry attacks", 19 Dec 2017	https://www.gov.uk/government/news/foreign-office-minister-condemns-north-korean-actor-for-wannacry-attacks	3 Nov 2026	Confirmed
40	NVD API record, CVE-2017-0144	https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2017-0144	3 Nov 2026	Confirmed
41	CISA Known Exploited Vulnerabilities catalog (JSON)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	3 Nov 2026	Confirmed
42	FBI Most Wanted, Yuriy Sergeyevich Andrienko	https://www.fbi.gov/wanted/cyber/yuriy-sergeyevich-andrienko	3 Nov 2026	Confirmed
43	Microsoft On the Issues, "The need for urgent collective action to keep people safe online", 14 May 2017	https://blogs.microsoft.com/on-the-issues/2017/05/14/need-urgent-collective-action-keep-people-safe-online-lessons-last-weeks-cyberattack/	3 Nov 2026	Confirmed
44	The White House (archived), press briefing on the attribution of WannaCry to North Korea, 19 Dec 2017	https://trumpwhitehouse.archives.gov/briefings-statements/press-briefing-on-the-attribution-of-the-wannacry-malware-attack-to-north-korea-121917/	3 Nov 2026	Confirmed
45	US-CERT/CISA Alert TA17-181A, Petya ransomware, 1 Jul 2017	https://www.cisa.gov/news-events/alerts/2017/07/01/petya-ransomware	3 Nov 2026	Confirmed
46	US government joint analysis report JAR-16-20296A, "GRIZZLY STEPPE", 29 Dec 2016 (PDF)	https://www.cisa.gov/sites/default/files/publications/JAR_16-20296A_GRIZZLY%20STEPPE-2016-1229.pdf	3 Nov 2026	Confirmed
47	CISA advisory AA22-057A, destructive malware, 26 Feb 2022 (rev. 28 Apr 2022)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-057a	3 Nov 2026	Confirmed
48	Mercy A. Kuo, *The Diplomat*, interview with Ben Buchanan, 24 Mar 2020	https://thediplomat.com/2020/03/the-hacker-and-the-state-cyberattacks-and-the-new-normal-of-geopolitics/	3 Nov 2026	Reported
49	Tom Uren, *Inside Story*, "War by other means" (review), 28 Apr 2020	https://insidestory.org.au/war-by-other-means/	3 Nov 2026	Reported
50	Angus Parker, *Geographical*, review, 27 May 2020, republished by Georgetown CSET	https://cset.georgetown.edu/article/the-hacker-and-the-state-cyber-attacks-and-the-new-normal-of-geopolitics-by-ben-buchanan-book-review/	3 Nov 2026	Reported
51	Enescan Lorci, book review, *Uluslararasi Iliskiler* 22(86), 2025 (abstract page)	https://www.ir-journal.com/issues/volume-22-number-86-2025/book-review-the-hacker-and-the-state-cyber-attacks-and-the-new-normal-of-geopolitics	3 Nov 2026	Reported

#	Source	URL	Opened	Grade
52	Library data: `data/attack/technique_profiles.jsonl`, `superseded_by.jsonl`, `software_profiles.jsonl`, `group_profiles.jsonl`, `group_to_technique.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl`	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	3 Nov 2026	Confirmed
53	Library tree: generated `mitre/` pages and `navigator/library-layers/`	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre	3 Nov 2026	Confirmed
54	Library pages: `CYBERSECURITY_BOOK_LIST.md` (line 1136), `NOTABLE_INCIDENTS.md` (line 84) and `MALWARE_FAMILIES.md` (lines 440 and 568)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/CYBERSECURITY_BOOK_LIST.md	3 Nov 2026	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents (OPM, Sony, Shamoon, Bangladesh Bank, WannaCry and NotPetya rows; the Aurora correction in Part 8.3)
- Threat Actors (APT1, APT28, APT29, Lazarus Group, APT38, Sandworm Team) and Malware Families (Regin, Shamoon, WannaCry, NotPetya)
- CVE Reference (CVE-2017-0143 to CVE-2017-0148)
- Cybersecurity Book List (*The Hacker and the State*)
- Home studies for events summarized here: Stuxnet, Sandworm: The Operations in the Public Record (the Ukrainian grid and NotPetya), The Zero-Day Trade and Its Fallout (the Shadow Brokers leak and WannaCry)
- Related case studies: China-Attributed Threat Actors, Russia-Attributed Threat Actors, North Korea-Attributed Threat Actors, Iran-Attributed Threat Actors, United States-Attributed Threat Actors, APT41: The Public Record (the Chinese espionage line after APT1), Log4Shell (patch-gap lessons after WannaCry)
- MITRE group pages: G0006, G0007, G0016, G0032, G0034, G0082
- MITRE software pages: S0002, S0019, S0023, S0117, S0140, S0364, S0366, S0368, S0603
- MITRE campaign pages: C0025, C0028

- MITRE technique pages for the core rows: T1566.001, T1566.002, T1078, T1078.002, T1021.002, T1543.003, T1561.002, T1485, T1486, T1210, T1565.001, T1657, T1685.005, and every row in Parts 9.2 to 9.5
- Navigator layers, including this study's layer, hacker-and-the-state-cases.json
- CWE Reference, CAPEC Reference, D3FEND Reference
- All case studies